

Chapitre 4

L'atténuation des risques

Feuille d'exercices

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Exercices du chapitre

Exercice 1 — Choisir la réponse au risque et les contrôles internes

- (a) Le cours distingue les risques opérationnels « externes » — « liés à l'environnement d'affaires ou à des événements extérieurs », qui « ne peuvent être réduits qu'en diminuant l'exposition ou en optimisant la réponse d'atténuation » — des risques « internes » — « liés aux personnes, processus et systèmes » — « bien plus maîtrisables, principalement par les contrôles internes, dans une logique active de compromis rendement-coût ». Expliquer précisément pourquoi un risque externe ne se prête pas au même « compromis rendement-coût actif » qu'un risque interne : sur quel levier, au juste, une organisation peut-elle agir pour un risque externe si elle ne peut ni en modifier la cause ni le contrôler directement ? Donner un exemple de risque externe et un exemple de risque interne, différents de ceux du cours, et justifier leur classement.
- (b) La norme ISO 31000 distingue quatre réponses au risque, les « 4 T » : « Tolérer » (« accepter le risque tel quel, pour les risques inhérents faibles ou déjà bien maîtrisés »), « Traiter » (« toutes les mesures d'atténuation, principalement les contrôles internes »), « Transférer » (« déplace la conséquence du risque vers un tiers [...] sans jamais transférer la responsabilité vis-à-vis du client ») et « Terminer » (« supprime toute l'exposition en cessant l'activité concernée — une réponse extrême, réservée aux cas où les inconvénients dépassent clairement les bénéfices »). Tolérer et Terminer sont les deux réponses « extrêmes » du dispositif, aux antipodes l'une de l'autre. Expliquer ce qui les distingue précisément en termes de niveau de risque inhérent visé, et pourquoi le cours qualifie spécifiquement Terminer de réponse « extrême » alors qu'il ne qualifie pas Tolérer de la même façon, quand bien même les deux réponses n'impliquent, par construction, aucune mesure d'atténuation active.
- (c) Le cours distingue quatre types de contrôles internes : les contrôles « préventifs » (« réduisent la probabilité d'un incident en agissant sur ses causes — la séparation des tâches en est l'exemple le plus connu, appliquée par exemple entre l'initiation, la validation et le règlement d'une transaction »), « détectifs » (« signalent la survenue d'un incident et accélèrent sa résolution — rapprochements de comptes, systèmes de détection d'activité réseau suspecte »), « correctifs » (« réduisent l'impact une fois l'incident survenu — sauvegardes de données, plans de continuité ») et « directifs » (« politiques, procédures, formations — structurent la conduite des opérations en amont de tout événement »). Un établissement constate qu'un même incident (un virement erroné exécuté puis découvert trois jours plus tard lors d'un rapprochement mensuel) aurait pu être empêché par la séparation des tâches, détecté plus tôt par un rapprochement quotidien, atténué dans son impact par un plafond de réversibilité des virements, et rendu moins probable par une formation renforcée des opérateurs. Associer précisément chacune de ces quatre mesures correctives potentielles à l'un des quatre types de contrôles du cours, en justifiant chaque association par la définition retenue.
- (d) Le cours définit un « contrôle clé (ou primaire) » comme « suffisant à lui seul pour empêcher la matérialisation du risque », à la différence d'un contrôle secondaire qui « ne fait que renforcer un contrôle clé sans pouvoir, seul, neutraliser le risque », et précise que l'automatisation d'un contrôle, si elle « en accroît généralement la fiabilité », « transforme un risque de défaillance humaine en un risque de défaillance technologique ou de modèle, transformant un risque de probabilité élevée et d'impact faible en un risque de probabilité faible mais d'impact potentiellement systémique ». L'étude de cas de Knight Capital (2012) attribue la perte de 460 millions USD en 45 minutes à cinq défaillances précises : « réutilisation de code obsolète, contrôle de versions inadéquat, tests insuffisants, absence de hiérarchisation des alertes, et absence de procédure d'urgence pour activer le coupe-circuit ». Classer chacune de ces cinq défaillances selon le type de contrôle absent ou défaillant (préventif, détectif, correctif ou directif), en justifiant chaque classement. En quoi le coupe-circuit lui-même — un contrôle automatisé censé arrêter toutes les transactions — illustre-t-il très précisément la transformation de risque décrite par le cours : quel risque de probabilité élevée et d'impact faible ce coupe-circuit était-il censé traiter, et quel risque de probabilité faible et d'impact potentiellement systémique sa propre défaillance a-t-elle matérialisé ?

Exercice 2 — Tester les contrôles, l'erreur humaine et l'amélioration continue

- (a) Le cours ordonne quatre niveaux de test des contrôles par rigueur croissante : « l'auto-certification (ou enquête déclarative) offre l'assurance la plus faible, réservée aux contrôles secondaires à faible risque » ; « l'examen documentaire s'appuie sur des preuves écrites du processus et de ses résultats » ; « l'observation en temps réel du fonctionnement du contrôle est plus rigoureuse mais limitée dans le temps » ; et « la reperformance — reproduire le contrôle sur un échantillon et comparer les résultats, par exemple via le « client mystère » ou l'insertion de transactions fictives — constitue la forme de test la plus exigeante ». Pour chacun de ces quatre niveaux, identifier précisément ce qui le rend plus (ou moins) fiable que le niveau qui le précède immédiatement dans cette hiérarchie : qu'apporte l'examen documentaire que l'auto-certification ne peut pas garantir ? Qu'apporte l'observation en temps réel que l'examen documentaire ne peut pas garantir ? Qu'apporte enfin la reperformance que la seule observation ne peut pas garantir ?
- (b) Le cours met en garde : un contrôle mal conçu — « optimiste » (« exigeant une vigilance surhumaine du contrôleur ») ou « collectif » (« diluant la responsabilité entre plusieurs personnes, comme un contrôle à quatre yeux mal implémenté ») — « peut donner un faux sentiment de sécurité », et que « répondre à une défaillance de contrôle en ajoutant simplement « plus de la même chose » dilue encore davantage la responsabilité au lieu de la renforcer ». Expliquer précisément le mécanisme par lequel un contrôle « collectif » — un contrôle à quatre yeux mal implémenté, par exemple — peut aboutir, en pratique, à ce que *personne* ne se sente responsable de sa bonne exécution. En quoi ajouter un troisième ou un quatrième regard à ce même contrôle à quatre yeux déjà mal implémenté aggraverait-il, plutôt qu'il ne résoudrait, ce problème de dilution de la responsabilité ?
- (c) James Reason distingue trois types d'actions humaines à l'origine d'incidents : le « glissement » (« une erreur involontaire due à l'inattention ou à la fatigue — la classique « faute de frappe » inversant un chiffre dans une transaction »), l'« erreur fondée sur des règles ou des connaissances » (« résulte d'un choix volontaire mais inadéquat — par exemple une vente inappropriée motivée par des incitations commerciales agressives ») et la « violation » (« l'auteur connaît la règle mais choisit délibérément de s'en écarter »). Le cours prescrit des réponses différenciées : « les glissements se traitent par un meilleur environnement de travail et une charge de travail adaptée », « les erreurs fondées sur les connaissances appellent des contrôles directifs — formation, procédures documentées, fichiers d'aide », et « les violations se traitent par des contrôles de supervision (hiérarchiques ou automatisés) et par le renforcement d'une culture de conformité ». Un opérateur de back-office, épuisé par une fin de mois chargée, saisit un montant de virement avec un chiffre inversé. Un conseiller commercial, sciemment, vend un produit d'épargne inadapté au profil d'un client parce que sa prime dépend du volume de ventes. Un trader dépasse délibérément une limite de position qu'il connaît parfaitement, en pariant que personne ne le remarquera avant la clôture. Identifier le type d'action de James Reason illustré par chacun des trois cas, puis la réponse de gestion appropriée à chacun selon le cours. Pourquoi serait-il contre-productif d'appliquer au trader la réponse prescrite pour l'opérateur de back-office (un meilleur environnement de travail), et inversement ?
- (d) Le « Six Sigma et sa variante Lean Six Sigma visent à réduire la variabilité et le gaspillage des processus via le cycle DMAIC (définir, mesurer, analyser, améliorer, contrôler) », tandis que « le cycle PDSA (planifier, exécuter, étudier, agir), ou « roue de Deming », structure de façon similaire l'amélioration continue de la qualité, largement utilisé dans la santé et de plus en plus dans les services financiers ». Détailler les cinq étapes du DMAIC et les quatre étapes du PDSA, puis expliquer en quoi les deux cycles poursuivent, malgré des étapes nommées différemment, un objectif méthodologique commun de réduction du risque *à la source*, plutôt qu'un traitement du risque une fois l'incident survenu. En quoi cette logique d'amélioration continue des processus complète-t-elle, sans s'y substituer, les quatre types de contrôles internes de l'exercice 1 ?

Exercice 3 — Projets, continuité, transfert du risque et réputation

- (a) Le processus d'approbation des nouveaux produits (NPAP) et sa généralisation aux nouvelles initiatives (NIRAP) « exigent qu'un dossier d'affaires couvre au minimum cinq volets : objectif, alternatives envisagées, bénéfices attendus, aspects commerciaux, et risques et leur atténuation », l'« intensité de l'implication de la fonction risque » dépendant de « la criticité du projet ». Le cours ajoute que, contrairement au risque de crédit d'un portefeuille acquis, « généralement bien documenté », le risque opérationnel d'une entité acquise est un « squelette dans le placard » qui « peut ne se révéler que des mois, voire des années après la transaction — car il résulte de processus, de personnes et de systèmes construits progressivement, souvent mal documentés au moment de la diligence raisonnable ». Pourquoi le cinquième volet exigé par le NPAP/NIRAP — « risques et leur atténuation » — est-il structurellement plus difficile à documenter dans le cas d'une acquisition que dans celui d'un nouveau produit lancé en interne? En quoi la nature même du risque opérationnel — « résulte de processus, de personnes et de systèmes construits progressivement » — explique-t-elle pourquoi il ne se prête pas à une diligence raisonnable aussi systématique que le risque de crédit d'un portefeuille acquis?
- (b) La gestion de la continuité d'activité (BCM) est « un processus continu qui identifie les activités critiques, évalue leur vulnérabilité, et prépare les moyens de maintenir ou de rétablir rapidement le service en cas de sinistre », reposant notamment sur « une analyse d'impact sur l'activité (BIA), et des tests réguliers du plan de continuité (BCP) ». Elle distingue « le point de reprise (RPO, « recovery point objective ») », qui « indique le volume de données que l'organisation accepte de perdre en cas d'incident, déterminé par la fréquence des sauvegardes », du « délai de reprise (RTO, « recovery time objective ») », « la durée maximale d'interruption tolérable pour un processus ou un service ». Une gestion efficace de la crise qui suit un sinistre repose ensuite sur trois qualités — « la rapidité de la réponse, la compétence des intervenants [...], et la transparence vis-à-vis des parties prenantes » — et traverse quatre phases : « la crise [...], la réponse d'urgence [...], le rétablissement (reprise des opérations essentielles selon le RTO prévu), et la restauration (retour complet à la normale) ». Expliquer pourquoi le RPO se fixe *en amont* du sinistre (par la politique de sauvegarde), tandis que le RTO ne peut être respecté *qu'après* le sinistre, lors des phases de réponse d'urgence et de rétablissement. Montrer précisément à quelle phase, parmi les quatre citées, chacune des trois qualités (rapidité, compétence, transparence) est le plus directement mobilisée, en justifiant chaque association.
- (c) L'assurance externe « réduit la volatilité du résultat en échange d'une prime régulière, mais elle n'est jamais un transfert parfait : l'organisation reste exposée à la capacité et à la volonté de l'assureur d'indemniser, et le versement peut intervenir des mois après l'incident », et a du sens « pour les risques prévisibles, correctement tarifables, et facilement transférables — typiquement les événements extrêmes de type cyber ou interruption d'activité, plutôt que les petites pertes récurrentes que beaucoup de grands établissements préfèrent auto-assurer ». L'externalisation, elle, « transfère l'exécution d'une tâche à un tiers, et une partie du risque opérationnel qui lui est attaché — mais jamais la responsabilité vis-à-vis du client final », et peut selon les cas « réduire le risque global (délégation à un spécialiste plus compétent) ou l'augmenter (délocalisation motivée par la seule réduction des coûts) ». Pourquoi les « petites pertes récurrentes » sont-elles justement les moins bien adaptées à un transfert par assurance, alors même qu'elles sont, par construction, les plus « prévisibles » des deux catégories de pertes évoquées par le cours? Expliquer ensuite pourquoi la clause « jamais la responsabilité vis-à-vis du client final » s'applique aussi bien à l'assurance qu'à l'externalisation : quel principe commun aux deux formes de transfert du risque cette double négation vient-elle protéger?
- (d) Une communication de crise efficace suit trois principes, les « trois R » : « le regret, reconnaissance sincère et excuse pour l'incident; la raison, explication transparente des causes et des responsabilités de l'établissement; le remède, une solution satisfaisante d'indemnisation des parties prenantes affectées ». L'étude de cas de la violation de données Capital One (2019) illustre cette approche : « signalement rapide aux autorités, excuses publiques du PDG assumant l'entière responsabilité, communication transparente du détail des données compromises, indemnisation ciblée [...] et générale [...] », les contrôles préventifs existants ayant

par ailleurs « limité l'ampleur réelle du préjudice ». Le cours conclut enfin que « la réputation agit comme une source de résilience : elle confère aux organisations une capacité accrue à s'adapter face aux difficultés externes et à rebondir après une dégradation de performance. Une gestion exemplaire de la crise renforce à son tour la réputation — la relation fonctionne dans les deux sens ». Associer précisément, dans le cas Capital One, chacune des mesures citées (signalement aux autorités, excuses du PDG, communication transparente, indemnisation ciblée, indemnisation générale) à celui des trois R (regret, raison, remède) qu'elle illustre le mieux. En quoi la phrase finale du cours — « la relation fonctionne dans les deux sens » — explique-t-elle pourquoi Capital One a pu, malgré une défaillance de contrôle initiale sévère, préserver une partie de son capital réputationnel plutôt que de le voir s'effondrer durablement ?

2 Exercice cumulatif (chapitres 4, 3, 2, 1, introduction)

Exercice 4 — L'atténuation des risques à la lumière des chapitres 3, 2, 1 et de l'introduction

- (a) Le chapitre 3 oppose la résilience à « la gestion de continuité d'activité classique (BCM), articulée autour de chaque processus et de son délai de reprise (RTO) », et définit la RCSA comme un exercice qui « évalue la probabilité et l'impact d'un risque avant l'effet des contrôles en place (risque inhérent) et après (risque résiduel) ». Ce chapitre est précisément celui qui donne un contenu à ces deux notions que le chapitre 3 se contentait de nommer ou de présupposer : il définit la BCM comme « un processus continu qui identifie les activités critiques [...] et prépare les moyens de maintenir ou de rétablir rapidement le service », le RTO comme « la durée maximale d'interruption tolérable », et surtout les quatre types de contrôles — préventifs, détectifs, correctifs, directifs — qui sont exactement les « contrôles en place » dont le chapitre 3 mesure l'effet sur l'écart entre risque inhérent et risque résiduel. Montrer que l'ordre de lecture du cours (mesure au chapitre 3, atténuation au chapitre 4) ne coïncide pas ici avec l'ordre de dépendance conceptuelle : pour comprendre pleinement en quoi la résilience du chapitre 3 se distingue de la « BCM classique » et pour savoir ce que « l'effet des contrôles » de sa propre RCSA désigne concrètement, le lecteur du chapitre 3 devait déjà, implicitement, connaître une partie de la matière que ce chapitre expose seulement après lui. En quoi cela illustre-t-il que le cycle en quatre étapes du cours (identification, évaluation, atténuation, surveillance) est un cycle *itératif*, où chaque étape présuppose déjà un peu de la suivante, plutôt qu'une séquence strictement linéaire où chaque notion n'apparaîtrait qu'une seule fois ?
- (b) Le chapitre 2 clôt sa propre présentation des contrôles internes par une phrase qui annonce très précisément ce chapitre : « les contrôles internes se classent en quatre catégories : les contrôles préventifs (réduisent la probabilité en agissant sur les causes), détectifs (identifient l'événement pendant ou après sa survenue), correctifs (réduisent l'impact d'un incident déjà survenu), et directifs (procédures, formations et lignes directrices qui structurent la conduite des opérations). **Le chapitre 4 détaille ces contrôles.** » Comparer terme à terme cette définition du chapitre 2 à celle que ce chapitre donne des mêmes quatre types de contrôles (« préventifs [...] agissant sur ses causes [...] détectifs [...] signalent la survenue d'un incident et accélèrent sa résolution [...] correctifs [...] réduisent l'impact une fois l'incident survenu [...] directifs [...] structurent la conduite des opérations en amont ») : montrer que les deux définitions coïncident presque mot pour mot, et identifier précisément ce que ce chapitre y ajoute que le chapitre 2 n'avait pas encore fourni (exemples concrets, hiérarchie de contrôles clés et secondaires, quatre niveaux de test, risque de l'automatisation). Par ailleurs, le chapitre 2 organise les *causes* du risque opérationnel selon le sigle « PPSE » — « personnes, processus, systèmes, événements externes ». Montrer que la typologie de James Reason (glissement, erreur, violation) que ce chapitre développe est un raffinement interne à la seule catégorie « personnes » de cette taxonomie PPSE : pourquoi les trois autres catégories (processus, systèmes, événements externes) ne se prêtent-elles pas au même type de décomposition par *intention* de l'acteur que la catégorie « personnes » ?
- (c) Le chapitre 1 définit les trois lignes de défense — « la première ligne de défense [...] responsable de l'identification, de l'évaluation et de la maîtrise quotidienne des risques inhérents à son

activité [...] la deuxième ligne [...] chargée de développer le cadre de gestion des risques et d'exercer une supervision et un rôle de challenge [...] la troisième ligne est l'audit interne, qui fournit une assurance indépendante » — et rapporte que, après la perte de 4,9 milliards d'euros de Jérôme Kerviel, une grande banque française a « diffus[é] dans tout le groupe des retours d'expérience anonymisés sur des incidents passés ». Montrer comment les quatre niveaux de test des contrôles de ce chapitre (auto-certification, examen documentaire, observation, reperformance) se répartissent naturellement entre les trois lignes de défense du chapitre 1 : quel niveau de test relève typiquement de l'auto-évaluation par la première ligne elle-même, et quel niveau exige au contraire l'indépendance propre à la deuxième ou à la troisième ligne ? Comparer ensuite le cas Kerviel du chapitre 1 (une violation délibérée d'une limite de trading, dissimulée pendant des mois) au cas Knight Capital de ce chapitre (une défaillance de contrôle automatisé et de gestion du changement) à l'aide de la typologie de James Reason : lequel des deux cas relève d'une « violation » au sens strict du chapitre 4, et lequel relève plutôt d'une accumulation de défaillances de contrôles préventifs, détectifs et directifs sans intention délibérée de nuire ? En quoi cette différence de nature explique-t-elle pourquoi le premier cas a nécessité, selon le chapitre 1, une réponse de culture et de supervision (partage des leçons apprises), tandis que le second a appelé, selon ce chapitre, une réponse technique de gestion du changement et de contrôle de version ?

- (d) L'introduction pose le cycle en quatre étapes en désignant chaque chapitre à l'avance : « leur atténuation par des contrôles ou d'autres mesures (chapitre 4) », une désignation que ce chapitre confirme dès sa première phrase : « après l'identification et l'évaluation, ce chapitre couvre la troisième étape du cycle de gestion des risques : l'atténuation ». L'introduction attribue par ailleurs au risque opérationnel cinq traits structurants, dont deux retiennent particulièrement l'attention ici : il est « à queue épaisse » (« une multitude de petites pertes coexistent avec un petit nombre de pertes extrêmes ») et « dynamique » (« sa nature évolue avec celle de l'activité et de l'environnement de l'organisation »). Montrer que l'automatisation des contrôles décrite par ce chapitre — qui « transforme un risque de probabilité élevée et d'impact faible en un risque de probabilité faible mais d'impact potentiellement systémique » — est un mécanisme concret par lequel une organisation *déplace elle-même* un risque le long de la queue épaisse décrite par l'introduction, et par lequel le risque devient « dynamique » au sens précis de l'introduction : ce n'est plus seulement l'environnement externe qui fait évoluer la nature du risque, c'est la propre décision de gestion de l'organisation (automatiser un contrôle) qui le fait. Par ailleurs, l'introduction affirme que « tout le monde est un gestionnaire du risque » parce que le risque opérationnel « ne peut pas être centralisé ». Montrer que la séparation des tâches, contrôle préventif exemplaire de ce chapitre appliqué « entre l'initiation, la validation et le règlement d'une transaction », est la traduction opérationnelle la plus directe de ce principe de décentralisation posé dès l'introduction : pourquoi un contrôle préventif de ce type ne pourrait-il, par construction, jamais être exécuté par une seule fonction centrale de gestion du risque opérationnel ?

3 Applications en sciences économiques

Exercice 5 — Assurance externe et auto-assurance d'un risque opérationnel, chiffrés

Une banque évalue son exposition à un risque de cyberattaque. La fréquence annuelle des événements est modélisée par une loi de Poisson de paramètre $\lambda = 4$ événements par an. La sévérité de chaque événement est résumée par trois bandes empiriques :

Bande de sévérité	Perte de la bande (k€)	Probabilité
Bande 1 (pertes courantes)	200	60 %
Bande 2 (pertes intermédiaires)	2 000	32 %
Bande 3 (événement extrême, queue)	15 000	8 %

La banque envisage de souscrire une police d'assurance externe avec une franchise (déductible) $D = 300$ k€ par événement et un plafond de garantie de $L = 8\,000$ k€ par événement : l'assureur indemnise la tranche de perte comprise entre D et $D + L$, la banque conservant à sa charge la partie de la perte en deçà de D et au-delà de $D + L$. La prime annuelle demandée par l'assureur est $P = 6\,200$ k€.

- Calculer la sévérité moyenne par événement (moyenne des trois bandes pondérée par leur probabilité), puis la perte annuelle attendue de la banque si elle n'est pas assurée (auto-assurance totale), égale à λ fois cette sévérité moyenne.
- Pour chacune des trois bandes de sévérité, calculer le montant retenu par la banque et le montant cédé à l'assureur compte tenu de la franchise D et du plafond L . En déduire le montant retenu moyen et le montant cédé moyen par événement, puis la perte annuelle attendue retenue par la banque (avec assurance) et la perte annuelle attendue cédée à l'assureur (les sinistres annuels attendus par l'assureur).
- Calculer le chargement (loading) implicite de l'assureur, c'est-à-dire l'écart relatif entre la prime P demandée et les sinistres annuels attendus calculés au (b). Calculer ensuite le coût total annuel attendu de la banque avec assurance (prime plus perte annuelle attendue retenue) et le comparer au coût total annuel attendu sans assurance calculé au (a). Ce surcoût attendu de l'assurance est-il compatible avec l'affirmation du cours selon laquelle l'assurance « réduit la volatilité du résultat en échange d'une prime régulière », sans pour autant réduire le coût attendu ?
- Supposons que l'événement de la bande 3 (perte de 15 000 k€) se matérialise effectivement au cours de l'année. Calculer le décaissement total de la banque cette année-là si elle est assurée (prime déjà payée plus montant retenu de cet événement) et si elle ne l'est pas (perte totale à sa charge). Comparer les deux montants. Le cours indique que l'assurance a du sens « pour les risques prévisibles, correctement tarifables, et facilement transférables — typiquement les événements extrêmes [...] plutôt que les petites pertes récurrentes que beaucoup de grands établissements préfèrent auto-assurer ». Ce résultat, combiné à celui du (b) sur la bande 1 (entièrement sous la franchise), illustre-t-il bien cette prescription ?

Exercice 6 — Contrôles automatisés et coût d'un incident majeur, chiffrés

Un incident de code défectueux dans le système de routage d'ordres d'une société de courtage génère des pertes à un rythme constant de 650 k€ par minute dès son déclenchement, jusqu'à l'arrêt effectif du système. En l'absence de tout contrôle détectif ou correctif automatisé, l'équipe technique met 38 minutes à identifier le problème, puis 4 minutes supplémentaires à arrêter manuellement le système.

- Calculer la perte totale de l'incident dans ce scénario sans contrôle automatisé (durée totale : identification plus arrêt manuel).
- La société envisage d'installer un système de détection automatisée des anomalies, qui ramènerait le délai d'identification à 3 minutes (l'arrêt restant manuel, donc 4 minutes supplémentaires). Elle envisage en complément un coupe-circuit automatique qui, une fois l'anomalie détectée par le système précédent, arrêterait le système en 1 minute au lieu de 4. Calculer la perte totale de l'incident dans chacun de ces deux scénarios (détection automatisée seule ; détection automatisée et coupe-circuit automatique), puis la perte évitée par la détection automatisée seule (par rapport à l'absence de tout contrôle) et la perte supplémentaire évitée par l'ajout du coupe-circuit automatique (par rapport à la détection automatisée seule).
- La probabilité qu'un tel incident (défaillance de code lors d'un déploiement) se produise au cours d'une année donnée est estimée, à partir des données de l'industrie, à $p = 5\%$, indépendamment des contrôles envisagés (ceux-ci réduisent la perte en cas de survenue, non la probabilité de survenue elle-même). Calculer la perte annuelle attendue dans chacun des trois scénarios du (a) et du (b), puis la réduction de perte annuelle attendue permise par la détection automatisée seule, et la réduction supplémentaire permise par l'ajout du coupe-circuit automatique. Le système de détection automatisée coûte 850 k€ par an ; le coupe-circuit automatique coûte 620 k€ par an de plus. Calculer le bénéfice net (réduction de perte attendue moins coût) de chacun des deux investissements pris isolément (détection seule par rapport à l'absence de contrôle ; coupe-circuit en supplément de la détection). Chacun des deux

investissements est-il justifié sur le seul critère de la perte attendue ?

- (d) Le cours avertit que l'automatisation d'un contrôle « transforme un risque de probabilité élevée et d'impact faible en un risque de probabilité faible mais d'impact potentiellement systémique », comme l'illustre le cas de Knight Capital où l'absence de « procédure d'urgence pour activer le coupe-circuit » a aggravé un incident déjà en cours. Au vu du résultat du (c) sur le coupe-circuit automatique, la société devrait-elle renoncer à cet investissement au seul motif qu'il n'est pas justifié en perte attendue ? Quel argument, au-delà du calcul de perte attendue, le cours fournit-il pour continuer à envisager ce type d'investissement malgré un bénéfice net négatif au sens strict ?